



ROAD TO HALL OF FAME

Explotando un Path Traversal con Burp Suite 

Actividad 07 · Reporte de laboratorio

Ingeniería en Tecnologías de la Información

Universidad Politécnica de San Luis Potosí

Fundamentos de Ciberseguridad

Mtro. Servando López Contreras

18 de septiembre de 2026

JUAN FRANCISCO ORTEGA JIMÉNEZ - 184918

Road to Hall of Fame 🏆 — Explotando un Path Traversal con Burp Suite

1. Datos generales del laboratorio

Nombre del laboratorio	File path traversal, simple case
Nivel	Apprentice
Tipo de explotación	Path Traversal / Directory Traversal
Objetivo del laboratorio	Obtener el contenido del archivo /etc/passwd explotando el parámetro "filename" que carga imágenes de productos sin validar la ruta.
URL del laboratorio	https://portswigger.net/web-security/file-path-traversal/lab-simple

2. Explicación técnica de la vulnerabilidad

La aplicación vulnerable ofrece una función "View details" para cada producto, la cual carga una imagen mediante una petición similar a la siguiente:

```
GET /image?filename=58.jpg
```

El servidor concatena directamente el valor recibido en el parámetro "filename" a la ruta base donde se almacenan las imágenes, sin validar ni sanear la entrada del usuario. Esto permite que un atacante sustituya el nombre del archivo por una secuencia de salto de directorios ("../") para escapar de la carpeta de imágenes y acceder a archivos arbitrarios del sistema operativo del servidor, como /etc/passwd.

Esta vulnerabilidad se clasifica dentro de OWASP Top 10 como parte de A01:2021 – Broken Access Control, ya que rompe el control de acceso esperado sobre el sistema de archivos del servidor.

3. Procedimiento paso a paso

- Abrir Burp Suite Community Edition y crear un "Temporary project in memory", usando la configuración por defecto ("Use Burp defaults").
- En la pestaña Proxy > HTTP history, dar clic en "Open browser" para abrir el navegador Chromium integrado, ya configurado para enviar su tráfico a través de Burp (evita configurar manualmente proxy/certificados).
- Dentro de ese navegador, acceder a la URL del laboratorio e iniciar sesión con la cuenta de PortSwigger; dar clic en "Access the lab".
- En la tienda ("We Like To Shop"), dar clic en "View details" de cualquier producto para generar tráfico hacia el servidor.
- Ajustar el filtro de Burp: por defecto, HTTP history oculta el contenido de imágenes ("Hiding CSS and image content"). Fue necesario abrir el filtro, marcar la casilla "Images" en "Filter by MIME type" y quitar "jpg,png" del campo "Hide" en "Filter by file extension", ya que la petición vulnerable es justamente una imagen.
- Con el filtro corregido, localizar en HTTP history una petición GET `/image?filename=NOMBRE.jpg`.
- Seleccionar esa petición, clic derecho → "Send to Repeater" (o Ctrl+R), e ir a la pestaña Repeater.
- En Repeater, reemplazar el valor del parámetro filename por: `../../../../etc/passwd`, cuidando no dejar espacios entre el signo "=" y el payload (un primer intento con espacios de más devolvió "400 Bad Request" / "No such file").
- Enviar la petición corregida (Send / Ctrl+Enter) y revisar el panel de respuesta: el servidor devuelve "HTTP/2 200 OK" con el contenido completo de `/etc/passwd`.

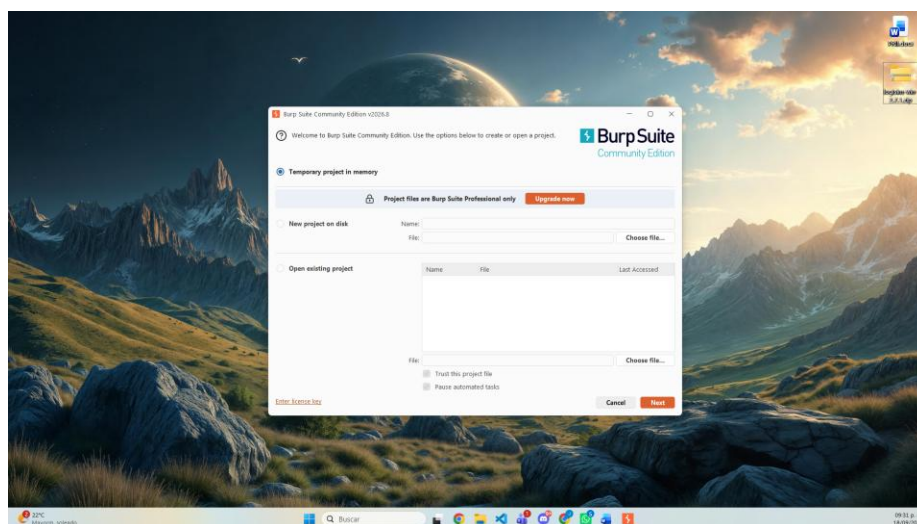
- Regresar a la pestaña del laboratorio, refrescar la página y confirmar que el estatus cambia a "Lab solved".

4. Evidencias fotográficas del proceso

A continuación se documenta, en orden cronológico, cada paso realizado durante la explotación del laboratorio, con su captura de pantalla correspondiente.

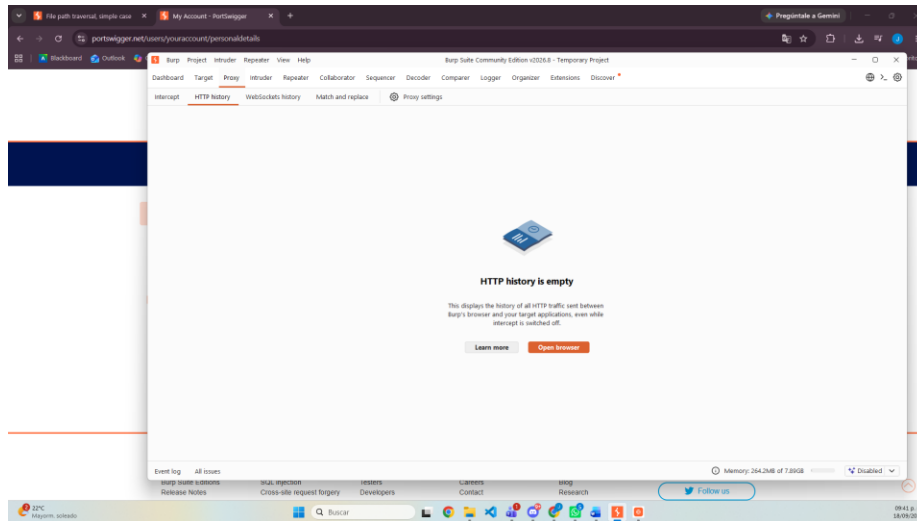
4.1 Configuración inicial de Burp Suite

Se inició Burp Suite Community Edition y se seleccionó la opción "Temporary project in memory" con la configuración por defecto, para trabajar sin guardar un proyecto en disco.



4.2 Primer intento fallido: navegador incorrecto

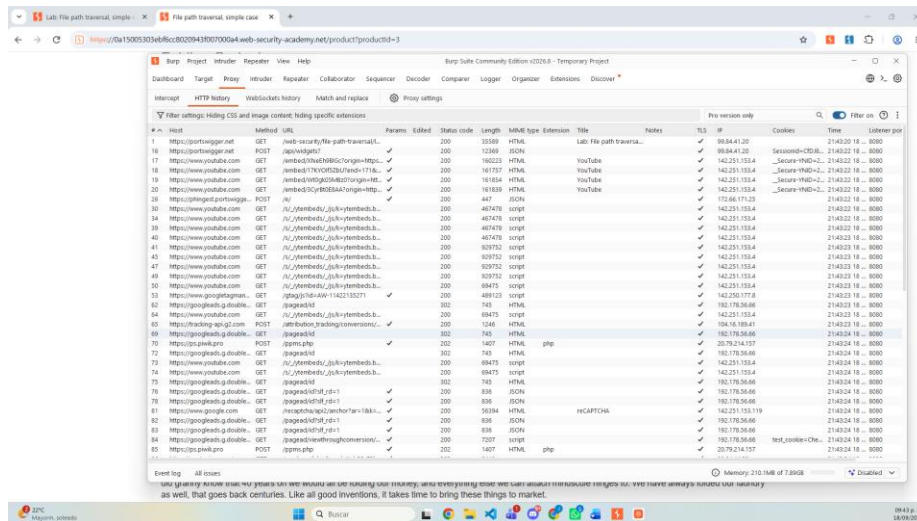
Al navegar el laboratorio desde el navegador Chrome normal (no el integrado de Burp), la pestaña Proxy > HTTP history apareció vacía, ya que ese tráfico no pasa por el proxy de Burp.



💡 Solución aplicada: se utilizó el botón "Open browser" de Burp para abrir el navegador Chromium integrado, que sí enruta el tráfico a través del proxy.

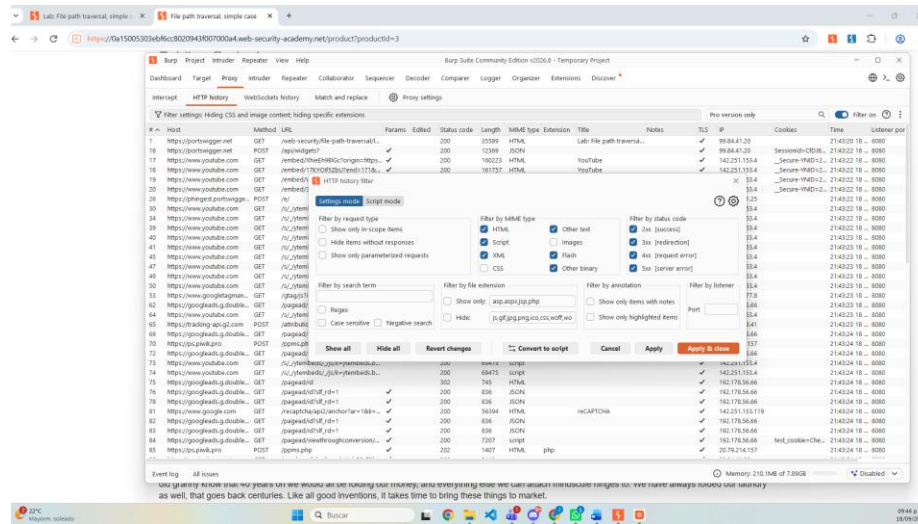
4.3 Tráfico capturado con el navegador correcto

Una vez usando el navegador integrado de Burp y con la sesión iniciada en PortSwigger, HTTP history comenzó a registrar peticiones (portswigger.net, recursos de terceros, etc.). Sin embargo, el filtro por defecto seguía ocultando el contenido de imágenes.



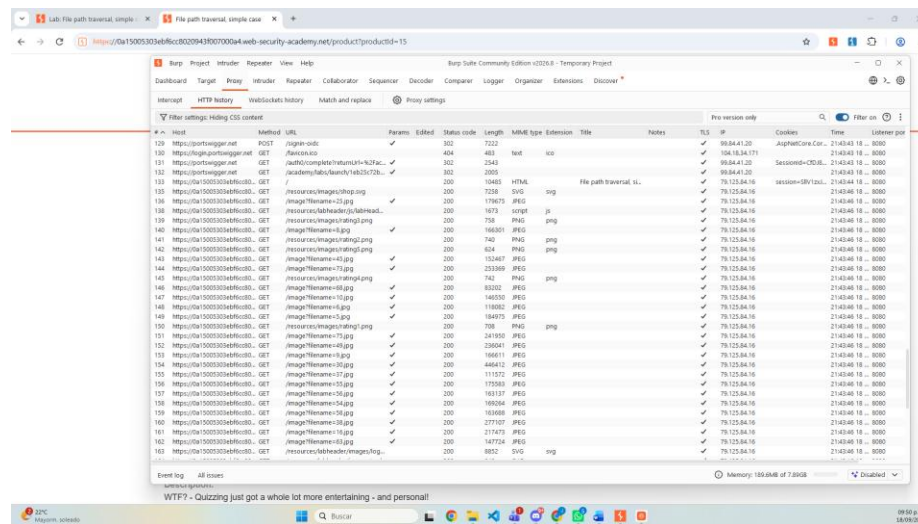
4.4 Ajuste del filtro de HTTP history

Se abrió el diálogo de filtros de HTTP history y se identificó que la casilla "Images" (en "Filter by MIME type") estaba desmarcada, y que el campo "Hide" en "Filter by file extension" incluía las extensiones jpg y png. Se marcó "Images" y se quitaron esas extensiones del campo "Hide" para poder visualizar las peticiones a archivos de imagen.



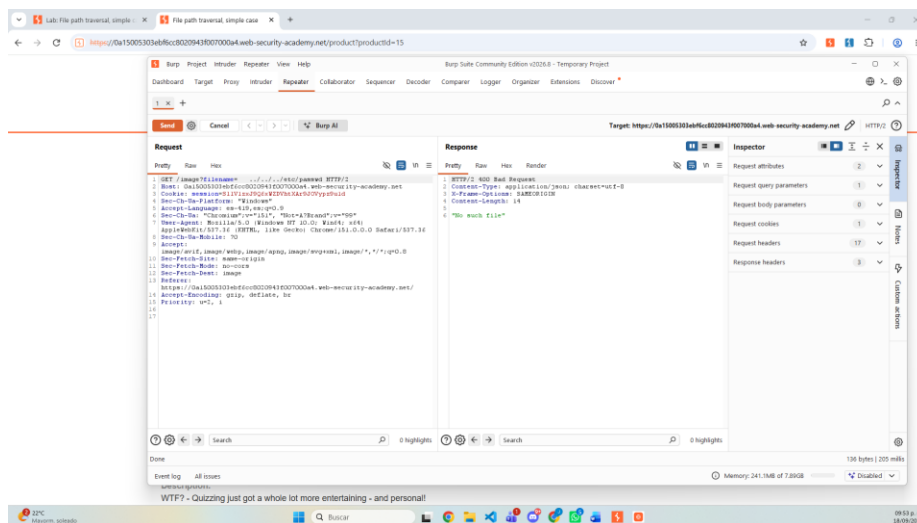
4.5 Request interceptado

Con el filtro corregido, se navegó de nuevo a la tienda y se dio clic en "View details" de varios productos. En Proxy → HTTP history aparecieron múltiples peticiones GET /image?filename=XX.jpg, confirmando que ahora sí se podían interceptar las peticiones a imágenes.



4.6 Primer intento de payload (con error)

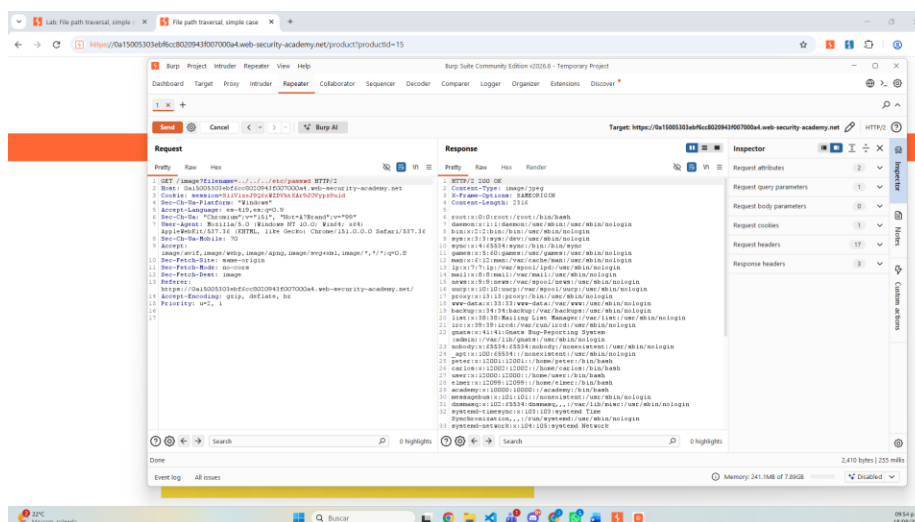
Se envió la petición seleccionada a Repeater (Send to Repeater) y se modificó el parámetro filename por `../../../../etc/passwd`. En el primer intento se dejó un espacio de más entre el signo "=" y el payload, lo que provocó una respuesta "400 Bad Request" con el mensaje "No such file".



💡 Nota: este error permitió identificar y corregir el formato exacto del payload.

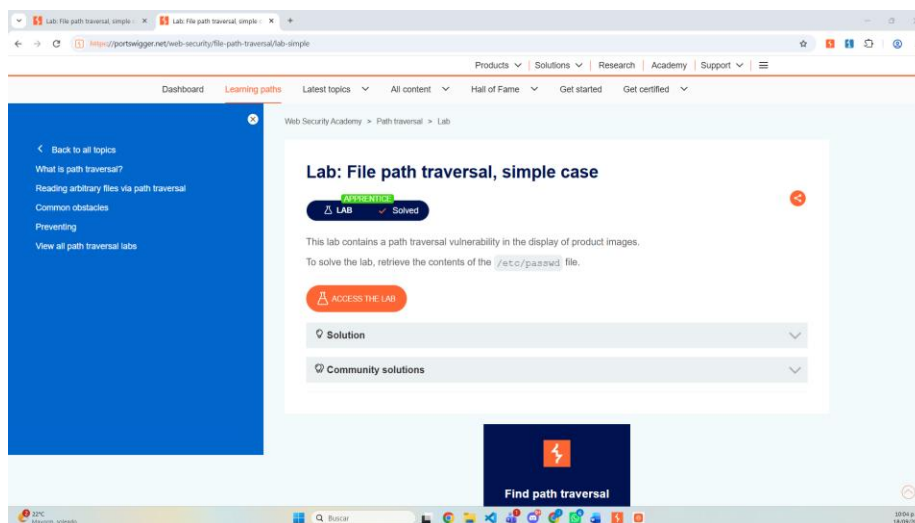
4.7 Payload corregido y respuesta vulnerable

Se eliminaron los espacios sobrantes, dejando el parámetro como `filename=../../../../etc/passwd` sin separaciones. Al reenviar la petición, el servidor respondió "HTTP/2 200 OK" devolviendo el contenido completo del archivo `/etc/passwd` del sistema.



4.8 Confirmación "Lab Solved"

Al regresar a la página oficial del laboratorio en PortSwigger, el indicador de estado cambió de "Not solved" a "Solved", confirmando que el objetivo de recuperar el contenido de `/etc/passwd` se cumplió exitosamente.



5. Explicación del payload

Payload utilizado: `../../../../etc/passwd`

- Cada secuencia "../" indica al sistema de archivos que suba un nivel en la jerarquía de directorios, partiendo de la carpeta donde se almacenan las imágenes (por ejemplo, /var/www/images/).
- Al encadenar varias secuencias "../" se logra llegar hasta la raíz del sistema de archivos ("/").
- Desde la raíz, "etc/passwd" apunta al archivo estándar de Linux que contiene la lista de cuentas de usuario del sistema.
- El servidor concatena esta cadena a su ruta base sin validarla, por lo que termina leyendo y devolviendo un archivo que se encuentra fuera del directorio previsto para imágenes.

6. Incidencias durante la práctica

- Filtro de contenido en Burp: por configuración por defecto, Burp Suite oculta el tráfico de imágenes y CSS en HTTP history. Fue necesario modificar "Filter by MIME type" y "Filter by file extension" para poder visualizar las peticiones a /image?filename=.
- Error de sintaxis en el payload: al modificar el parámetro filename en Repeater se dejaron espacios de más entre "=" y el valor del payload, generando una respuesta "400 Bad Request" con el mensaje "No such file". Se corrigió eliminando los espacios y dejando filename=../../../../etc/passwd sin separaciones, tras lo cual el servidor respondió correctamente con "200 OK".

7. Mitigación recomendada

- Validar y sanear la entrada del usuario, rechazando secuencias como "../", "..\" o sus variantes codificadas en URL (%2e%2e%2f).

- Utilizar listas blancas (whitelisting) de nombres de archivo permitidos, en lugar de aceptar cualquier valor arbitrario.
- Resolver la ruta canónica del archivo (por ejemplo, con funciones como `realpath()`) y verificar que el resultado permanezca dentro del directorio autorizado.
- Usar identificadores indirectos (por ejemplo, un ID numérico mapeado internamente a la ruta real) en lugar de recibir directamente el nombre o ruta del archivo.
- Aplicar el principio de mínimo privilegio, ejecutando la aplicación con permisos restringidos para limitar el impacto de una posible lectura no autorizada.

8. Conclusión

Este laboratorio permitió comprender de forma práctica cómo una validación de entrada insuficiente puede derivar en una vulnerabilidad de Path Traversal, así como el uso de Burp Suite (Proxy y Repeater) para interceptar, modificar y reenviar peticiones HTTP con el fin de explotar dicha vulnerabilidad de manera controlada.

Referencias

PortSwigger. (2026). File path traversal, simple case [Laboratorio interactivo]. Web Security Academy. <https://portswigger.net/web-security/file-path-traversal/lab-simple>

OWASP Foundation. (2021). OWASP Top 10:2021 – A01 Broken Access Control. https://owasp.org/Top10/A01_2021-Broken_Access_Control/